# Identifying Risk Factors and Vulnerabilities (Part 1)

## Network architecture, vulnerable and obsolete software, and the vulnerability scan report

Class 6 · Friday, November 6, 2026 · 6:00 – 10:00 pm · Online · Topic 4 — Identifying Risk Factors and Vulnerabilities (Part 1)

*Case organization: Kalmia Coffee Roasters Inc. (fictional) · Quiz 2 follows the lecture · Legal Notice v2.0 applies to every lab*

# The one fact to remember

A vulnerability is a property of a system; a risk factor is that vulnerability in its context. The same weakness is a small problem on an isolated device and a serious one on a flat network, on the Internet or on the roaster computer. Every weakness you record tonight needs three things: the evidence that proves it, the path that makes it reachable, and the asset that would suffer.

**evidence** **path** **asset**

# Tonight's hour — three lessons on the clock

| | |
|---|---|
| 0:00 – 0:04 | Opening — the one fact, objectives, legal frame |
| 0:04 – 0:24 | Lesson 1 — Network architecture: segmentation, exposed services, remote access, wireless |
| 0:24 – 0:42 | Lesson 2 — Vulnerable and obsolete software: end of support, missing patches, default configurations |
| 0:42 – 0:58 | Lesson 3 — Reading and interpreting a vulnerability scan report |
| 0:58 – 1:00 | Closing — what comes next (Quiz 2, Class 7, midterm, Lab 2) |

# By the end of this hour you will be able to

- Identify network-architecture vulnerabilities — segmentation, exposed services, remote access, wireless — each with its evidence
- Recognize vulnerable and obsolete software — end of support, patch gap, default configurations — and give every row a status
- Read a vulnerability scan report — scope, CVSS, severity vs priority, false positives — and turn findings into Lab 3 rows
- Competency EZ02, element 3: criteria 3.1 and 3.2 (3.4 introduced)

**Remember**

Three goals, one per lesson, each one a column of Lab 3.

# Legal and ethical frame — read before any lab

## Legal Notice v2.0 — tonight's sections

- §6.1 Authorization governs everything
- §7.6 Scanning is intrusive: designated targets only, no ‘harmless’ sweeps
- §7.6 Credentialed scans need written authorization (Annex D)
- §7.6 Cloud targets: check the provider's testing policy first
- §7.5 A scan report is a confidential finding

## Links and integrity

- §14 / Annex C: check every link on VirusTotal before opening it
- §18 Academic integrity: your words, your sources
- Kalmia is fictional; addresses come from documentation ranges
- Criminal Code s. 342.1 · CFAA · Dir. 2013/40/EU · LO 10/1995
- Full text: cyber-soho.github.io/prevmon (Legal Notice)

# Kalmia — the evidence trail so far

- Torréfaction Kalmia inc. — roastery + office in Saint-Laurent, 3 cafés, 46 employees, ≈ $6.8 M (fictional)
- Nadia Roy — CEO and risk owner · Lucas Martin — IT (half-time) · InfoNord MSP manages FW-HQ
- Head office: one network for everything — HQ-LAN 192.168.10.0/24
- W-01 ROAST-PC on Windows 10 + vendor remote access · W-02 flat network · W-03 NAS-01 shared admin password
- W-05 outdated web-shop plugins · W-06 no offboarding · W-07 cameras on factory passwords
- Lab 1 gave the inventory and the scan · Lab 2 the threats · tonight: the weaknesses

**Remember**

Warning signs are not conclusions: tonight they become evidence or they close.

# 1

# Lesson 1 — Threats and vulnerabilities related to network architecture

Segmentation, exposed services, remote access and wireless — and how each weakness is proved with evidence

**0:04 – 0:24 · 13-minute script**

# From warning signs to vulnerabilities

- Vulnerability — a weakness that a threat source could exploit or trigger (NIST SP 800-30 Rev. 1)
- Risk factor — any input that sets the level of risk: threat, vulnerability, impact, likelihood, predisposing condition
- Predisposing condition — a property of the organization or its architecture that makes harm more (or less) likely
- A flat network is not a product flaw: it makes every product flaw more dangerous
- EZ02 criterion 3.1 — network architecture · criterion 3.2 — obsolete applications and services

**Remember**

Three definitions from NIST SP 800-30 Rev. 1; the flat network is the predisposing condition.

# Network architecture: four questions

- Who can talk to whom inside the network? → segmentation
- What is listening, and to whom? → exposed services
- Who can come in from outside, and how? → remote access
- What does the radio reach? → wireless
- Each answer needs evidence: zone table, scan line, flow list, Wi-Fi survey

**Remember**

Four questions = the four families of this lesson.

# Segmentation — the vocabulary

- Network segmentation — separate subnets / VLANs with filtering (ACL) between them
- Zone — devices with the same trust level and protection needs
- North-south traffic: in and out of the organization (perimeter firewall)
- East-west traffic: inside the building (only segmentation controls it)
- Flat network — one zone, no internal filtering: every device reaches every port
- Lateral movement (MITRE ATT&CK) needs no special technique on a flat network

**Remember**

East-west traffic is controlled only by segmentation.

# Zones and deny by default (ITSG-38)

| Zone | What it holds | Kalmia today | Rule between zones |
|---|---|---|---|
| Public Zone | The Internet and everything Kalmia does not control | Internet, ISP networks, customers | Untrusted: everything that comes in is filtered |
| Public Access Zone (comparable to a DMZ) | Services that must be reachable from the Internet | Web shop (hosted outside); FW-HQ administration portal (should not be there) | Only the published service ports; no direct path to internal zones |
| Operations Zone | Ordinary workstations and internal servers | PCs, NAS-01 — but in the same network as everything else | Default deny from less trusted zones; only required flows |
| Restricted / OT zone | Production systems that must keep running | ROAST-PC and LOG-ROAST-01 — not separated | Only the documented flows (weekly copy to NAS-01; vendor access through a controlled path) |
| Device zone (cameras, IoT, printers) | Devices that are rarely patched | Cameras, thermostat, printers — not separated | May reach their recorder or cloud service only |
| Guest / BYOD zone | Visitors' and employees' personal devices | Kalmia-Invite in the cafés (isolated); phones on Kalmia-HQ (not isolated) | Internet only; no route to any internal zone |
| Management zone | Administration interfaces and the administration workstation | Does not exist: PC-IT-01 administers from the flat network | Administration ports reachable only from here |

# Kalmia evidence — HQ-LAN is one flat zone

- One subnet: 192.168.10.0/24 — 18 scanned hosts, 8 device families, filtering: none
- Critical assets inside: NAS-01, PC-IT-01, ROAST-PC (OT)
- Untrusted devices in the same zone: cameras (2 on factory passwords), thermostat, printer, phones, LOG-ROAST-01, EXT-WH-01
- Each of them can open NAS-01's file-sharing ports and PC-IT-01's remote desktop
- OT (ROAST-PC) is kept apart from IT in good designs: hard to patch, stops production
- Strength: café guest Wi-Fi isolated (tested Oct 22) — controls that work are recorded too

**Remember**

Lab 1 zone table: internal filtering 'none'. Nine untrusted devices reach NAS-01 and PC-IT-01.

# Exposed services — three kinds

- Service = program answering on a port (0–65535, TCP/UDP); exposed = reachable where not needed
- 1 · Clear-text administration — Telnet 23, HTTP 80, appliance pages on other HTTP ports
- 2 · Remote administration reachable from everywhere — RDP 3389, SSH 22
- 3 · Management interface on the Internet — firewall, router or storage login page
- CISA BOD 23-02: remove management interfaces from the Internet or protect them

**Remember**

Service, port, open, exposed. Then the three kinds.

# Kalmia evidence — what the scan shows

| Kind | Where (Lab 1 scan of the lab replica) | Rows |
|---|---|---|
| Clear-text administration | Telnet: SW-HQ, CAM-HQ-3, CAM-HQ-4 · HTTP: switch, cameras, printers, extender, NAS-01:5000 | NA-03 … NA-15 |
| Remote administration from everywhere | RDP 3389 + SMB on PC-IT-01 · SMB on PC-FIN-01 | NA-05, NA-06, NA-07 |
| Management interface on the Internet | FW-HQ portal 198.51.100.24:443 (source restriction not demonstrated) | NA-16 (HIGH) |
| Administration on the Internet | Web shop SSH 203.0.113.40:22 from any address | NA-17 (HIGH) |

# Remote access — methods and four questions

- VPN — encrypted tunnel into the network
- RDP or SSH published directly
- Remote-support agents (MSP, vendor): outgoing connection to a relay; unattended access = nobody approves
- Four questions: who · from where · how authenticated · until when
- Safeguards: MFA · end date · session record · reach only the system to support
- No open inbound port ≠ no remote access path

**Remember**

A remote-support agent needs no inbound port: the evidence is the contract and the outgoing traffic.

# Kalmia's three remote paths

| Path | MFA | End date | Logged | Verdict |
|---|---|---|---|---|
| F-07 InfoNord → FW-HQ portal | yes | 2027-06-30 | yes | Safeguards present; exposure to verify |
| F-06 RoastTech → ROAST-PC (RoastLink, unattended) | unknown | none | unknown | NA-19 HIGH |
| F-08 LOG-ROAST-01 → vendor cloud (undeclared) | unknown | none | unknown | NA-20 MEDIUM |
| F-04 PC-IT-01 → every device (HTTPS, SSH, RDP) | no | — | no | NA-18 MEDIUM |

# Wireless — modes and weaknesses

| Mode | How a device is admitted | Main weakness | Verdict |
|---|---|---|---|
| Open (no password) | Anyone joins | Traffic readable by everyone around unless each site uses HTTPS | Guest networks only, with isolation |
| WEP / WPA (original) | Shared key | Broken protocols | Never acceptable |
| WPA2-PSK (Personal) | One password shared by everyone | The password can be tested offline after one handshake capture; it stays valid for people who left | Acceptable only with a long password changed at every departure |
| WPA3-SAE (Personal) | One password, protected exchange | Still one shared password | Preferred for small sites |
| WPA2/WPA3-Enterprise (802.1X) | Individual account checked by a RADIUS server | Needs a server and certificates | Recommended for staff networks |

**Also: rogue access point · evil twin · WPS left on by default (NIST SP 800-153)**

# Kalmia's Wi-Fi evidence

- Kalmia-HQ: WPA2-PSK unchanged since 2022-03-15 (1,697 days), bridged into HQ-LAN → NA-21 HIGH
- EXT-WH-01: extender not in the inventory, repeats Kalmia-HQ into the warehouse, WPS on → NA-22 HIGH
- Plateau café router: WPS on (ISP default) → NA-24 LOW
- Kalmia-Staff (café): key 796 days old → NA-23 MEDIUM
- Kalmia-Invite: guests isolated, key changed Oct 1 → a strength

**Remember**

Four years, many departures, no offboarding (W-06).

# Writing a network-architecture risk factor

- ID (NA-01 …) · family · asset with its Lab 1 ID
- The weakness in one sentence
- The evidence: scan line, zone table, flow number, survey date
- A provisional level (HIGH / MEDIUM / LOW) — Lab 3 rates likelihood and impact
- Code example 1 → 24 rows: HIGH 8 · MEDIUM 15 · LOW 1
- Hours 2–3: check every row against its evidence

**Remember**

Six parts per row; the level is provisional until Lab 3.

# Schematic 1 — Zoning for Kalmia's head office

## Schematic 1 — Network zoning for Kalmia's head office: one zone today, zones with deny-by-default rules tomorrow

### TODAY — HQ-LAN 192.168.10.0/24

One zone · internal filtering: none (Lab 1 zone table)

- **server** — 1
  NAS-01
- **workstation** — 4
  PC-ADM-01, PC-FIN-01, PC-IT-01, PC-SHIP-01
- **OT** — 2
  ROAST-PC, LOG-ROAST-01
- **camera** — 3
  CAM-HQ-1, CAM-HQ-3, CAM-HQ-4
- **IoT** — 1
  THERMO-HQ
- **printer** — 1
  PRN-HQ-1
- **personal** — 1
  BYOD-PHONES
- **network** — 5
  FW-HQ, SW-HQ, AP-HQ-1, AP-HQ-2, EXT-WH-01

Families to protect (teal) share one zone with families to separate (rust): **risk factor NA-01 — flat zone (HIGH).** Grey = network equipment, managed from a management zone in the target design.

### TARGET — zones and documented flows (preview of Topic 7 and Lab 4, not a decision)

**Management zone**
PC-IT-01 (administration)

**Server zone**
NAS-01 (file shares)

**Office zone**
PC-ADM-01, PC-FIN-01, PC-SHIP-01, laptops

**Internal firewall — deny by default between zones**
(Canadian Centre for Cyber Security ITSG-38 · NIST SP 800-41)

**OT zone (roastery)**
ROAST-PC, LOG-ROAST-01

**Device zone**
cameras, printers, thermostat

**Guest / BYOD zone**
personal phones, Internet access only

**Allowed flows — everything else is blocked**

1 Office → Server: file sharing (SMB 445)

2 OT → Server: weekly copy of roast profiles (F-02)

3 Device → Server: camera recordings (RTSP 554, F-03)

4 Management → every zone: administration with MFA

5 Guest / BYOD → Internet only

**Remote access and wireless in the target**

Vendor support reaches the OT zone through one controlled access point: MFA, time-limited, every session recorded (replaces RoastLink's unattended, open-ended access).

Staff Wi-Fi: individual accounts (802.1X) in the office zone; guest Wi-Fi kept isolated (this already works in the cafés).

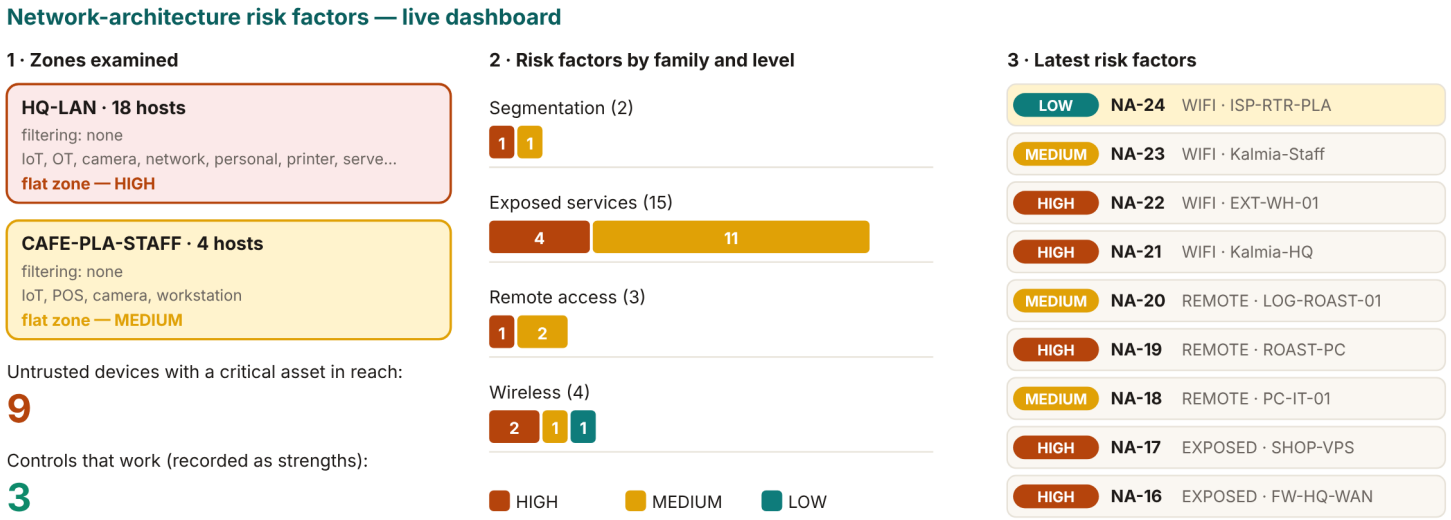
420-1C2-DW Threats and Risks · Class 6 (Fri Nov 6, 2026) · © 2026 Cyber.SoHo / Asen Grozdanov — educational material, fictional case (Kalmia)

# Real-life example — Kalmia's network-architecture risk factors

| Family | What the evidence shows | Example rows (level) |
|---|---|---|
| Segmentation | HQ-LAN mixes 8 device families with internal filtering “none”; 9 untrusted devices reach NAS-01 (22, 139, 445, 5000) and PC-IT-01 (139, 445, 3389). The café staff network mixes POS with a camera, a menu board and a laptop. | NA-01 HQ-LAN flat zone (HIGH) · NA-02 café staff zone (MEDIUM) |
| Exposed services | Telnet on SW-HQ, CAM-HQ-3, CAM-HQ-4; HTTP administration on 10 devices; RDP and SMB on PC-IT-01; SMB on PC-FIN-01; FW-HQ portal 443 and SHOP-VPS SSH 22 reachable from the Internet. | NA-09/NA-10 cameras with factory passwords (HIGH) · NA-16 FW-HQ portal on the Internet (HIGH) · NA-17 SSH on the web shop (HIGH) |
| Remote access | F-06 RoastLink → ROAST-PC: unattended, no end date, MFA and logging unknown. F-08 LOG-ROAST-01 → vendor cloud: undeclared. F-04 PC-IT-01 administers everything without MFA. | NA-19 RoastLink (HIGH) · NA-20 undeclared channel (MEDIUM) · NA-18 administration workstation (MEDIUM) |
| Wireless | Kalmia-HQ: WPA2 password unchanged for 1,697 days, bridged into HQ-LAN. EXT-WH-01: rogue extender, WPS on. ISP-RTR-PLA: WPS on. Kalmia-Invite: isolated (strength). | NA-21 stale key (HIGH) · NA-22 rogue extender (HIGH) · NA-24 WPS (LOW) |

**Feeds: Class 9 workshop (list of risk factors for the case organization — the 24 NA- rows are the 'network' starting list)**

# Code example 1 (Python) · videos




## kalmia_network_risk.py

- Reads 4 lab files: scan, zones, remote flows, Wi-Fi survey
- Check 1 segmentation · 2 exposed services · 3 remote access · 4 wireless
- Output: network_risk_factors.csv — 24 rows (HIGH 8)

```
            add("EXPOSED", h["host"], f"administration service {service} reachable fro
                # Evidence: the external address; HIGH because anyone on the Internet
                f"external scan of {h['ip']}; source restriction not demonstrated", "H
        # Internet hosts are finished; continue with the next host.
        continue
    # Clear-text administration: a password typed on these ports can be read on the ne
    clear = [f"{CLEARTEXT_ADMIN[p]} {p}/tcp" for p in ports if p in CLEARTEXT_ADMIN]
    # Record one finding per host that offers at least one clear-text administration p
    if clear:
        # A clear-text port on a device that still has its factory password is HIGH; o
        level = "HIGH" if "factory password" in h["note"] else "MEDIUM"
        # Record the clear-text administration service(s) of this host in a single row
        add("EXPOSED", h["host"], f"clear-text administration ({', '.join(clear)})",
            # Evidence: the scanned address and the walk-through note, then the level
            f"scan {h['ip']}; {h['note'] or 'no note'}", level)
    # Remote-control ports on an internal host are reachable from the whole flat zone.
    for p in [p for p in ports if p in REMOTE_ADMIN and h["family"] == "workstation"]:
        # Record it: remote control of a workstation is open to every device of the zo
        add("EXPOSED", h["host"], f"{REMOTE_ADMIN[p]} ({p}/tcp) reachable from every d
            # Evidence: the scanned address and port; MEDIUM because the zone has no i
            f"scan {h['ip']}:{p}; zone filtering: none", "MEDIUM")
    # File sharing on a workstation exposes its disk and its stored credentials to the
    if h["family"] == "workstation" and FILE_SHARING & set(ports):
        # Record it once per workstation.
```

Step **875** / 1592 · line **148** · the highlighted line has just been executed

VARIABLES CHANGED BY THIS STEP

*no variable changed by this line*

PROGRAM OUTPUT

```
scanned); PC-IT-01 (139,445,3389)
[REACH] BYOD-PHONES (personal; personal phones on the staff
Wi-Fi) -> NAS-01 (22,139,445,5000); ROAST-PC (not scanned);
PC-IT-01 (139,445,3389)
[ZONE] CAFE-PLA-STAFF (none): 4 hosts, families IoT, POS,
camera, workstation
[SEG][MEDIUM] NA-02 CAFE-PLA-STAFF: flat zone: devices to
separate share the network of the data to protect | evidence:
families IoT, POS, camera, workstation; internal filtering:
none
[EXPOSED][MEDIUM] NA-03 SW-HQ: clear-text administration
(Telnet 23/tcp, HTTP 80/tcp) | evidence: scan 192.168.10.2;
core switch
```

## Videos (≤ 15 min, verified Nov 6, 2026)

- ▶️ Network Segmentation · Professor Messer · 9:49
- ▶️ Secure Infrastructures · Professor Messer · 5:54
- ▶️ Secure Communication · Professor Messer · 9:55
- ▶️ Wireless Security Settings · Professor Messer · 10:54

# 2

# Lesson 2 — Vulnerable and obsolete applications, operating systems and services

End-of-support software, missing patches and default configurations — and the evidence that proves each one

**0:24 – 0:42 · 12-minute script**

# Every program has an end date

- Software lifecycle: release → mainstream support → extended support → end of support
- End of support (EOS / EOL): no more security updates from the vendor
- Every flaw found after that date stays open for good
- Fixes for supported versions show attackers where to look in unsupported ones
- Obsolete software — CWE-1104, unmaintained third-party components

**Remember**

EOS vs EOL: read the vendor's definition. Unsupported = future flaws stay open.

# One product, several clocks

| Product | End of support | Status on Nov 6, 2026 | Source |
|---|---|---|---|
| Windows 10 Home/Pro 22H2 | October 14, 2025 | Ended — security updates only through the ESU program (consumers to October 12, 2027; organizations up to three years, paid) | Microsoft |
| Windows 11 Home/Pro 24H2 | October 13, 2026 | Ended — move to 25H2 | Microsoft |
| Windows 11 Home/Pro 25H2 | October 12, 2027 | Supported | Microsoft |
| Windows 11 Enterprise/Education 24H2 | October 12, 2027 | Supported | Microsoft |
| PHP 8.1 | December 31, 2025 | Ended — no fix for the October 2026 vulnerabilities | php.net |
| PHP 8.2 | December 31, 2026 | Supported (security fixes only), ends in 55 days | php.net |
| RoastMaster 4.x (fictional) | March 31, 2027 | Supported — ends in 145 days | RoastTech contract (fictional) |

# Kalmia — what has ended, or ends soon

- Windows 10: ROAST-PC, SALES-LT1, SALES-LT2 — ended Oct 14, 2025, not enrolled in ESU
- Windows 11 Pro 24H2: PC-SHIP-01, PC-WH-01 — ended Oct 13, 2026 (updates waiting for a restart)
- Web shop: PHP 8.1.27 — ended Dec 31, 2025 (no fix for alert AL26-026)
- RoastMaster 4.2 — vendor support ends Mar 31, 2027: end of support soon (145 days)
- OT case: RoastTech forbids untested updates → compensating controls (Topics 6–7)

**Remember**

ROAST-PC: the vendor rule explains why the usual remedy is unavailable.

# Missing patches — the vocabulary

- Patch — a vendor change that corrects a defect or a vulnerability
- Security update · cumulative update (all previous fixes in one package)
- Patch Tuesday — Microsoft's monthly release, the second Tuesday (Oct 13, 2026; next Nov 10)
- Out-of-band update — published outside the schedule when too urgent to wait

**Remember**

Patch Tuesday: Oct 13 was the last, Nov 10 is the next.

# Patch management and the patch gap

- NIST SP 800-40 Rev. 4: identify · prioritize · acquire · install · verify
- Patch gap = time between the fix's publication and its installation
- Kalmia draft policy (InfoNord): 30 days for security updates — Lab 4 decides
- AL26-026 (PHP, Oct 21): proof of concept public → 5 days later exploitation and KEV listing
- A 30-day gap would have covered most of that window

**Remember**

Five verbs; 'verifying' is why a pending restart counts as a gap.

# Firmware, applications, plugins — Kalmia's pattern

- Automatic and current: office PCs (Oct 14), Microsoft 365 Apps (Oct 28)
- NAS-01: auto-update off, last update May 2024 (900 days)
- CAM-HQ-3/4: firmware from June 2019 (2,706 days) · printer: Feb 2021
- UpdraftPlus 1.26.4 — 1.26.5 (June 2026) fixes CVE-2026-10795 (NVD 8.1)
- Firmware has fixes too — but only if someone owns the task

**Remember**

What updates itself is current; what depends on a person is behind.

# Default configurations

- Default configuration — the settings out of the box
- Default credentials — factory user name and password, published in the manual
- Insecure defaults: Telnet on · SNMP 'public' · UPnP on · WPS on (CWE-1188)
- Mirai (2016): IoT devices taken over with their factory passwords
- CISA: default passwords are a bad practice; manufacturers should eliminate them

**Remember**

Defaults make installation easy, not the product safe.

# Hardening — and Kalmia's seven insecure configurations

- Hardening: new passwords, unused services off, encrypted administration only
- Configuration baseline — written secure settings (CIS Benchmarks); settings drift
- CAM-HQ-3, CAM-HQ-4: factory password + Telnet · PRN-HQ-1: 'public', no admin password
- EXT-WH-01: admin/admin + WPS · NAS-01: built-in admin + HTTP 5000
- Café router: label password, WPS, UPnP · POS: one manager PIN per café

**Remember**

Hardening against a written baseline (CIS Benchmarks).

# An exhaustive method — and why 'unknown' is a finding

- Start from the complete Lab 1 software inventory (criterion 3.2: exhaustive)
- Per row: version · vendor EOS date + source · last update · update mode · defaults
- Status: supported · ends soon · ended · patch gap · insecure configuration · unknown
- Kalmia unknowns: FW-HQ firmware (InfoNord), café router (ISP), camera firmware (model)
- Code example 2 → 34 findings: EOL 6 · soon 1 · gap 10 · config 7 · unknown 10

**Remember**

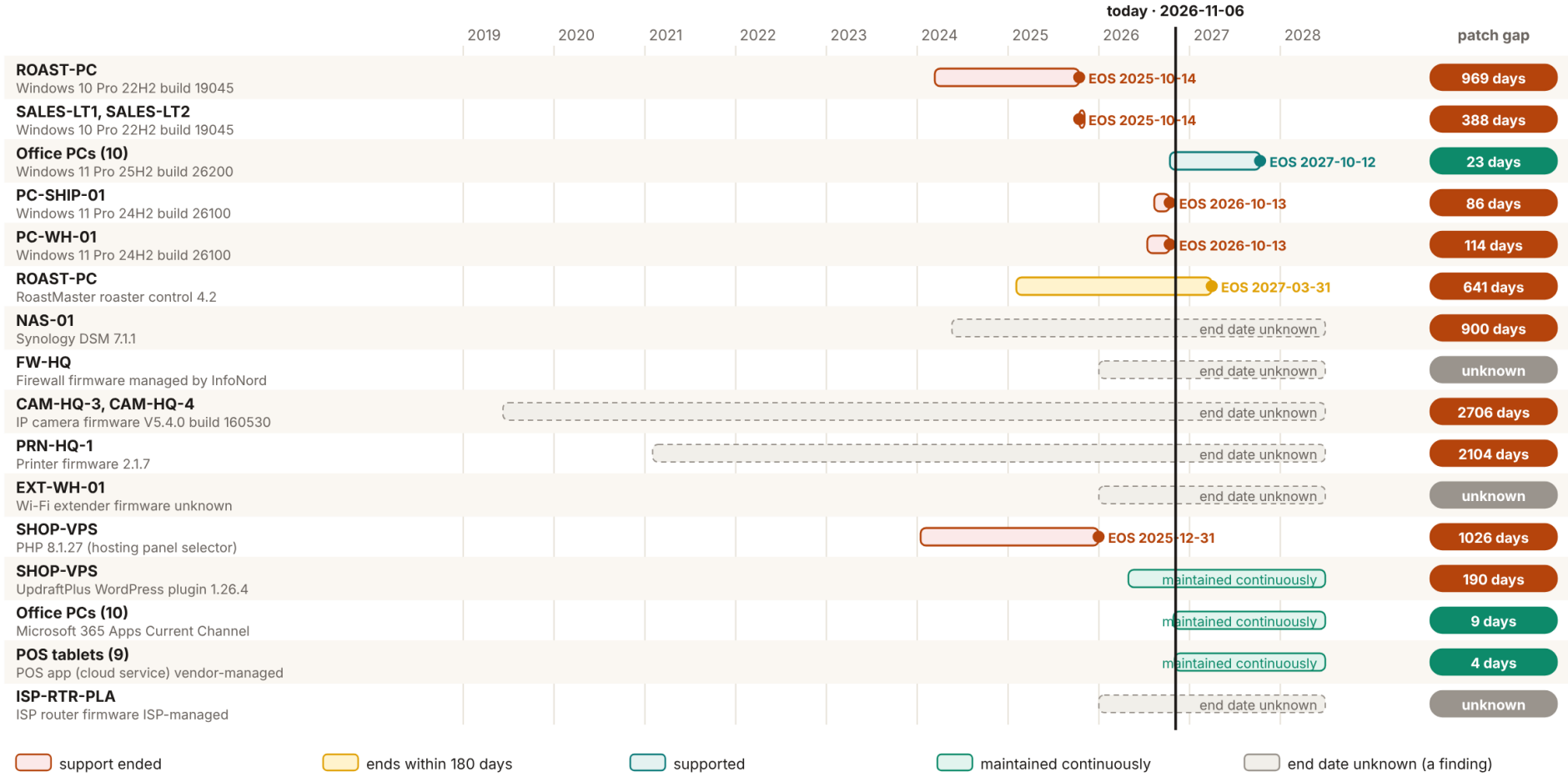
Every inventory row gets a status with a source. Unknown = a question with an owner.

# How the evidence is collected

| Question | Windows (PowerShell) | Linux / appliances |
|---|---|---|
| Which version is installed? | Get-CimInstance Win32_OperatingSystem \| Select-Object Caption, Version, BuildNumber | cat /etc/os-release · the device's status page |
| When was the last update installed? | Get-HotFix \| Sort-Object InstalledOn -Descending \| Select-Object -First 1 | apt history (/var/log/apt/history.log) · firmware page |
| Which updates are waiting? | winget upgrade (third-party applications) · Settings > Windows Update | apt list --upgradable |
| Is a restart pending? | Settings > Windows Update shows 'Restart required' | Presence of /var/run/reboot-required (Ubuntu) |
| Is the product still supported? | Microsoft Lifecycle page of the exact edition and version | Vendor lifecycle or end-of-life page (record the URL and the date) |

# Schematic 2 — Kalmia's software on the support timeline

## Schematic 2 — Kalmia's software on the support timeline (November 6, 2026)




Bar = from the last update installed to the vendor's end-of-support date. Badge = days since the last update (rust when above the 30-day draft policy).

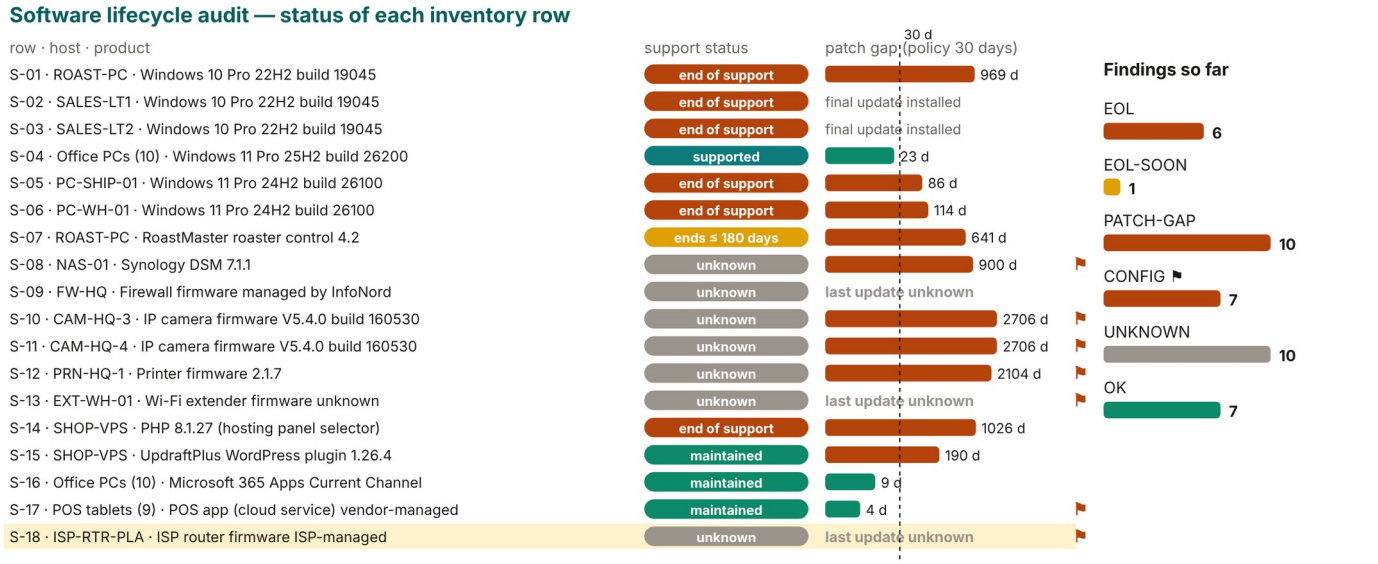
420-1C2-DW Threats and Risks · Class 6 (Fri Nov 6, 2026) · © 2026 Cyber.SoHo / Asen Grozdanov — educational material, fictional case (Kalmia)

# Real-life example — Kalmia's software lifecycle and patch-gap audit

| Status | Count | Kalmia rows (evidence) |
|---|---|---|
| End of support | 6 | ROAST-PC, SALES-LT1, SALES-LT2 — Windows 10 22H2 (Oct 14, 2025, not enrolled in ESU) · PC-SHIP-01, PC-WH-01 — Windows 11 Pro 24H2 (Oct 13, 2026) · SHOP-VPS — PHP 8.1.27 (Dec 31, 2025) |
| End of support soon | 1 | ROAST-PC — RoastMaster 4.2, vendor support until March 31, 2027 (145 days) |
| Patch gap (> 30 days) | 10 | ROAST-PC Windows (969 days, vendor-only) and RoastMaster (641) · PC-SHIP-01 (86) and PC-WH-01 (114), restart pending · NAS-01 (900, auto-update off) · CAM-HQ-3, CAM-HQ-4 (2,706) · PRN-HQ-1 (2,104) · PHP (1,026) · UpdraftPlus 1.26.4 (190) |
| Insecure configuration | 7 | NAS-01 built-in admin + HTTP 5000 · CAM-HQ-3, CAM-HQ-4 factory password + Telnet · PRN-HQ-1 SNMP 'public', no admin password · EXT-WH-01 admin/admin + WPS · POS shared manager PIN · ISP-RTR-PLA label password, WPS, UPnP |
| Unknown (evidence to obtain) | 10 | NAS-01 EOS · FW-HQ EOS and last update (InfoNord) · camera firmware EOS (×2) · printer EOS · EXT-WH-01 EOS and last update · ISP-RTR-PLA EOS and last update (ISP) |
| Supported, current | — | Office PCs (10) Windows 11 Pro 25H2, updated Oct 14 · Microsoft 365 Apps, updated Oct 28 · POS cloud app, updated Nov 2 |

**Feeds: Class 9 workshop (risk factors related to software, criterion 3.3 — the 34 SW- rows)**

# Code example 2 (Bash) · videos




```
100     # More than 180 days of support remain.
101     else
102       # Print the decision so that the reader sees the date that was checked.
103       echo "[OK] $host $product $version: supported until $eos ($left days left)"
104     # Close the test on the number of days left.
105     fi
106   # Close test 1.
107   fi
108
109   # Test 2 - patch gap: without a last-update date, the patch level cannot be demonstrated
110   if [ "$last" = "unknown" ]; then
111     # Count it and record it: the evidence must be requested from the person or company th
112     unk=$((unk + 1)); record "UNKNOWN" "$host" "$product" "$version" "last update date unkn
113   # An ended product whose last update is on or after the end date already has the final up
114   elif [ "$ended" -eq 1 ] && [ "$(date -u -d "$last" +%s)" -ge "$(date -u -d "$eos" +%s)" ]
115     # Print the explanation instead of a patch gap: the problem is the end of support, alre
116     echo "[INFO] $host $product: final update installed on $last; no newer update will be p
117   # A known date: compute the age of the last update in days.
118   else
119     # Age = (today - last update) in seconds divided by 86,400.
120     age=$(( ( TODAY_S - $(date -u -d "$last" +%s) ) / 86400 ))
121     # More days than the policy allows: security updates published since then are missing.
122     if [ "$age" -gt "$PATCH_DAYS" ]; then
123       # Count it and record it as PATCH-GAP with the age and the update mode, which explain
```

Step **350** / 637 · line **112** · the highlighted line has just been executed

VARIABLES CHANGED BY THIS STEP

**executed** `record UNKNOWN FW-HQ 'Firewall firmware' 'managed by InfoNord' 'last update date unknown (update mode: MSP)' 'ask the owner of the update process'`

PROGRAM OUTPUT

```
| last update 2025-02-03 (641 days > 30; mode: vendor-only)
[ROW] S-08 NAS-01 - Synology DSM 7.1.1 (update mode: manual (auto-update off))
[UNKNOWN] SW-11 NAS-01 | Synology DSM 7.1.1 | end of support not documented
[PATCH-GAP] SW-12 NAS-01 | Synology DSM 7.1.1 | last update 2024-05-20 (900 days > 30; mode: manual (auto-update off))
[CONFIG] SW-13 NAS-01 | Synology DSM 7.1.1 | built-in admin account enabled; HTTP administration on 5000
[ROW] S-09 FW-HQ - Firewall firmware managed by InfoNord (update mode: MSP)
[UNKNOWN] SW-14 FW-HQ | Firewall firmware managed by InfoNord | end of support not documented
```

## kalmia_lifecycle_audit.sh

- Bash: associative arrays, while-read loops, GNU date in UTC
- Test 1 lifecycle · Test 2 patch gap · Test 3 configuration
- Output: software_findings.csv — 34 findings

## Videos (≤ 15 min, verified Nov 6, 2026)

- ▶️ Vulnerability Types · Professor Messer · 14:32
- ▶️ Misconfiguration Vulnerabilities · Professor Messer · 7:09
- ▶️ Operating System Vulnerabilities · Professor Messer · 4:09

3

# Lesson 3 — Reading and interpreting a vulnerability scan report

What a scanner does, the anatomy of a report and a finding, CVSS, false positives, and the seven-step reading method

**0:42 – 0:58 · 11-minute script**

# What a vulnerability scanner does

- Discovers hosts and services, identifies software and versions, reads settings, compares with known vulnerabilities
- Each test = a plugin (Greenbone: NVT) · OpenVAS (open source) · Nessus (commercial)
- Vulnerability assessment: identifies probable weaknesses, does not exploit them
- Penetration test: tries to exploit them to prove the impact
- Unauthenticated scan: the network view · authenticated scan: logs in, reads packages and patches — far more accurate

**Remember**

Assessment identifies; a penetration test validates (NIST SP 800-115).

# Two rules before you open any report

- Scan only designated targets of the lab range, during the exercise (Legal Notice s. 7.6)
- Never the college's, an employer's or a café's network
- Credentialed scan: written authorization (Annex D)
- A scan report is a confidential finding (s. 7.5): need-to-know, never uploaded to a public service

**Remember**

Scanning is intrusive; the report is confidential.

# Anatomy of a report — read the header first

- Header: who, when, scanner + database date, targets, exclusions, credentials, hosts alive
- Summary: counts by severity and by host · then detailed results per host
- Kalmia: InfoNord, Nov 4, Greenbone, authorization signed by Nadia Roy on Nov 2
- ROAST-PC excluded (vendor request) · SALES-LT2 did not answer
- Not in the results ≠ safe → false negative risk

**Remember**

No date, scope or authorization = no evidence. Two coverage gaps at Kalmia.

# The fields of a finding

| Field | What it tells you |
|---|---|
| Name | What the problem is |
| Host · port | Where it was found (asset, address, service) |
| CVSS score + vector | Severity of the flaw in general, and how it was calculated |
| CVE | The public identifier of a known vulnerability |
| QoD | How sure the scanner is (below 70 % → verify) |
| Evidence | What the scanner actually saw: version, banner, successful login |
| Solution · references | The remedy and the vendor advisory |

# Reading severity — CVSS ratings and the vector

- None 0.0 (Log) · Low 0.1–3.9 · Medium 4.0–6.9 · High 7.0–8.9 · Critical 9.0–10.0 (FIRST; same in v4.0)
- CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H = 9.8 Critical
- AV network · AC low · PR none · UI none · S unchanged · C/I/A high
- Same vector with AC:H = 8.1 High
- Micro-activity: R16 AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N = 6.5 Medium

**Remember**

Read one vector aloud; change AC and watch 9.8 become 8.1.

# Severity is not priority

- CVSS base score = the flaw in general, in any organization
- KEV (CISA) — reliable evidence of exploitation in the wild
- EPSS (FIRST) — probability that exploitation activity is observed in the next 30 days
- Your Lab 1: is the host on the Internet? how critical is it?
- CISA SSVC: track · track closely · attend · act

**Remember**

CVSS measures severity, not risk. Priority adds exploitation, exposure and the asset.

# False positives — two in the Kalmia report

| Result | What the scanner saw | Why it is false | Lesson |
|---|---|---|---|
| R04 CVE-2024-4577 (9.8, KEV) | PHP/8.1.27 in a web header | The flaw concerns PHP-CGI on Windows; the server runs Linux | Check the platform |
| R05 CVE-2024-6387 regreSSHion (8.1) | Banner OpenSSH 8.9p1 | Ubuntu backported the fix: package 1:8.9p1-3ubuntu0.10 | Read the whole banner; prefer authenticated checks |

# Noise: Log results, low QoD, duplicates

- Informational (0.0, Log): open ports, OS detected, host not answering — inventory, not vulnerabilities
- Low QoD (< 70 %, hidden by default): a guess to verify — R17, possible default credentials on SW-HQ
- Duplicates: SMB signing not required on NAS-01, PC-FIN-01, PC-IT-01 = one action
- Remove false positives with a written reason that can be audited

**Remember**

Count actions, not lines.

# The seven-step reading method

| Step | What you do | Kalmia example |
|---|---|---|
| 1 Scope | Read date, targets, exclusions, credentials, hosts alive | ROAST-PC excluded; SALES-LT2 not alive |
| 2 Severity | Convert every CVSS score to its rating | 27 results: 11 Critical, 4 High, 8 Medium, 4 Log |
| 3 Noise | Set aside Log results and QoD below 70 | 4 Log results; R17 (QoD 30) to verify by hand |
| 4 Verify | Remove false positives with written reasons | R04 (Windows-only flaw on Linux) and R05 (backported fix) |
| 5 Group | One remediation action per problem | 20 results become 16 actions |
| 6 Prioritize | Score = CVSS + 3 (KEV) + 1 (EPSS ≥ 0.10) + 2 (Internet) + criticality 1–3 | P1 ≥ 14 (7 days) · P2 ≥ 11 (30 days) · P3 ≥ 8 (90 days) · P4 (180 days) |
| 7 Record | Write VS- rows with evidence for Lab 3 | scan_risk_factors.csv |

# Kalmia: 27 results → 16 actions

- P1 (due Nov 13): PHP 8.1 end of life on the web shop — 15.0
- P1: CVE-2017-7921 on CAM-HQ-3/4 — 14.8 (published 2017, in KEV since March 2026)
- P2 ×6 (due Dec 6) · P3 ×7 (Feb 4, 2027) · P4 ×1
- The scanner rated the FW-HQ portal by its ciphers; Lesson 1 rated its exposure HIGH
- Lab 3 combines NA-, SW- and VS- rows in one risk register

**Remember**

The highest raw line (R04, would be 18.8) was a false positive.

# Schematic 3 — Anatomy of a finding and the reading method

## Schematic 3 — Anatomy of a scan finding and the seven-step reading method

### One result of the Kalmia report (R18)

| | | |
|---|---|---|
| 1 | **Name** | Hikvision IP camera improper authentication |
| 2 | **Host · port** | CAM-HQ-3 · 192.168.10.52 · 80/tcp |
| 3 | **CVSS score · rating** | 9.8 · Critical |
| 4 | **Vector** | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| 5 | **CVE · KEV · EPSS** | CVE-2017-7921 · in KEV · EPSS 0.99998 |
| 6 | **QoD** | 80 % (version read from the web interface) |
| 7 | **Evidence** | firmware V5.4.0 build 160530, family DS-2CD2xx2F-I |
| 8 | **Solution** | update the firmware or replace the camera |

### What each field tells the analyst

1. What the problem is — the title a person reads first.
2. Where it was found: the asset, its address and the service.
3. Severity of the flaw in general (FIRST ratings). Not the priority.
4. How the score was built: read AV, AC, PR, UI, S and C/I/A.
5. Exploitation evidence: KEV (observed) and EPSS (probability).
6. How sure the scanner is; below 70 % a person must verify.
7. What the scanner actually saw — read it before you trust 1 to 6.
8. The remedy and the vendor reference (advisory).

### The seven-step reading method — Kalmia numbers at each step

| 1 Scope | 2 Severity | 3 Noise | 4 Verify | 5 Group | 6 Prioritize | 7 Record |
|---|---|---|---|---|---|---|
| 15 targeted · 14 alive | 27 results | 4 Log set aside | 2 false positives | 20 results | CVSS + KEV + EPSS | VS-01 … VS-16 |
| ROAST-PC excluded | 11 C · 4 H · 8 M · 4 Log | R17 QoD 30 → verify | R04 · R05 removed | → 16 actions | + Internet + criticality | P1 2 · P2 6 · P3 7 · P4 1 |

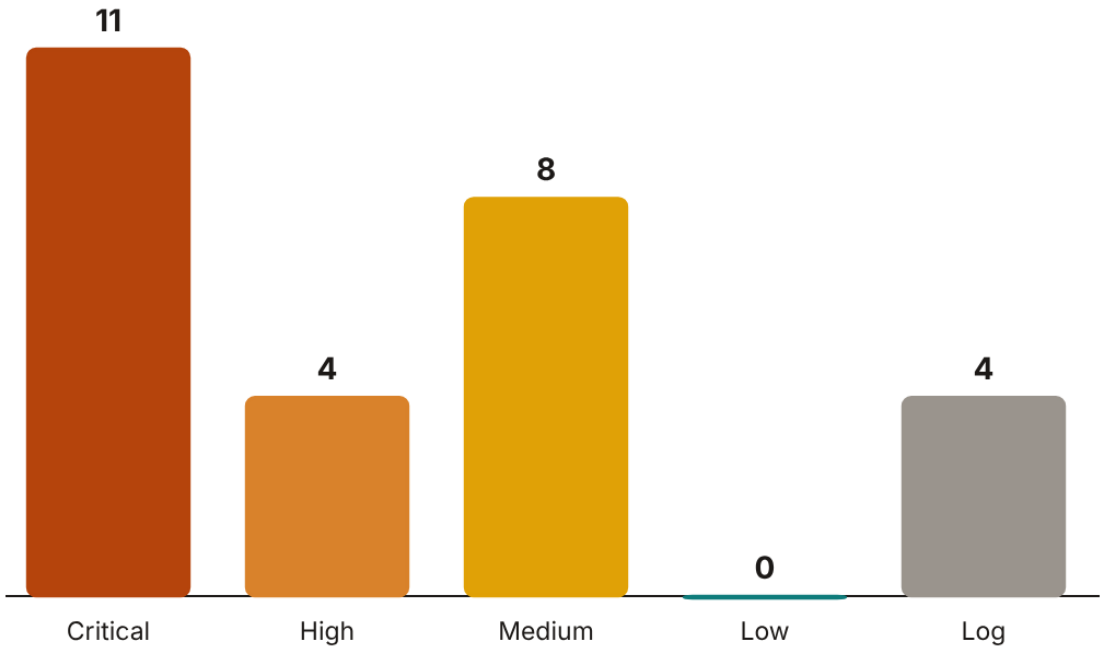
Priority rule (teaching aid): score = CVSS + 3 if in KEV + 1 if EPSS ≥ 0.10 + 2 if Internet-facing + asset criticality (1–3) · P1 ≥ 14 (7 days) · P2 ≥ 11 (30) · P3 ≥ 8 (90) · P4 (180).

420-1C2-DW Threats and Risks · Class 6 (Fri Nov 6, 2026) · © 2026 Cyber.SoHo / Asen Grozdanov — educational material, fictional case (Kalmia)

# Graph 3 — The report before and after reading

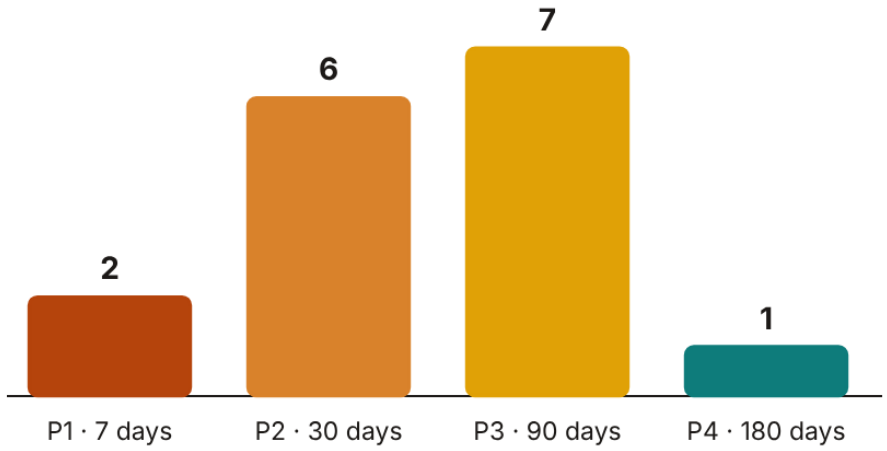
## Graph 3 — The Kalmia report before and after reading

**Raw report: 27 results by CVSS rating**




What the summary page shows, before any analysis.

**After the seven steps: 16 actions by priority**




−4 Log · −1 to verify (R17) · −2 false positives · 20 results → 16 actions.

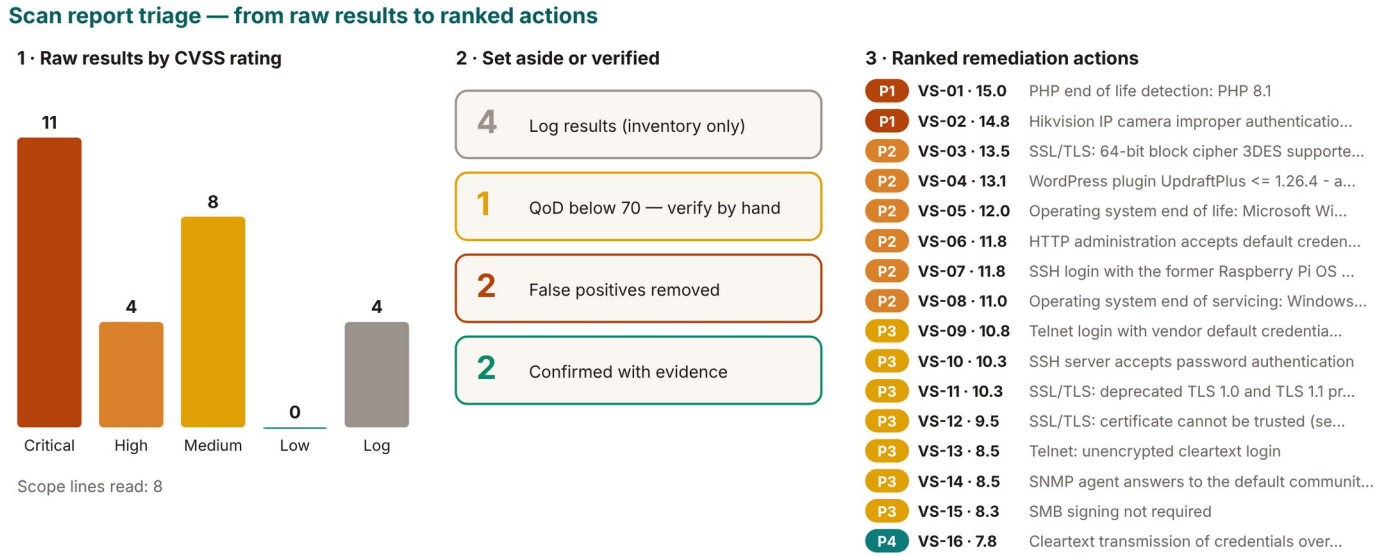
420-1C2-DW Threats and Risks · Class 6 (Fri Nov 6, 2026) · © 2026 Cyber.SoHo / Asen Grozdanov — educational material, fictional case (Kalmia)

# Real-life example — Reading the authenticated scan of the Kalmia lab replica

| Step | What the report shows | Decision |
|---|---|---|
| 1 Scope | Authorization signed Nov 2; 15 hosts targeted, 14 alive; ROAST-PC excluded (OT); SALES-LT2 not alive | Two coverage gaps recorded; ROAST-PC is assessed from the vendor's documents and Lesson 2's inventory instead |
| 2 Severity | 27 results: Critical 11, High 4, Medium 8, Low 0, Log 4 | Ratings computed from the CVSS scores |
| 3 Noise | R10, R25, R26, R27 are Log; R17 has QoD 30 | Log results go to the inventory check; R17 is verified by hand with Lucas Martin |
| 4 Verify | R04 CVE-2024-4577 (PHP-CGI, Windows only) on a Linux server; R05 CVE-2024-6387 with Ubuntu's fixed package | Two false positives removed, reasons recorded; R18 and R20 confirmed |
| 5 Group | 20 confirmed results; SMB signing on 3 hosts, cameras ×2 | 16 remediation actions |
| 6 Prioritize | PHP 8.1 EOL on SHOP-VPS: 10.0 + 0 + 0 + 2 + 3 = 15.0 · CVE-2017-7921 on CAM-HQ-3/4: 9.8 + 3 + 1 + 0 + 1 = 14.8 | P1 ×2 (due Nov 13) · P2 ×6 (Dec 6) · P3 ×7 (Feb 4, 2027) · P4 ×1 |
| 7 Record | VS-01 to VS-16 with result numbers as evidence | scan_risk_factors.csv → Lab 3 |

**Feeds: Lab 3 — Risk register and prioritization (the 16 VS- rows bring their score and due date**

# Code example 3 (Python) · videos




```
144     print(f"[GROUP] {len(kept)} confirmed results -> {len(groups)} remediation actions")
145
146     # ------------------------------------------------------------ Step 6 - priority
147     # The list of actions with their score.
148     actions = []
149     # Examine every group of results.
150     for name, rs in groups.items():
151         # The severity of the action is the highest CVSS among its results.
152         cvss = max(r["score"] for r in rs)
153         # KEV = the vulnerability is known to be exploited in the wild (CISA catalogue): +3
154         kev = 3 if any(r["kev"] == "yes" for r in rs) else 0
155         # EPSS = probability that exploitation activity is observed in the next 30 days: +1
156         epss = 1 if any(r["epss"] and float(r["epss"]) >= 0.10 for r in rs) else 0
157         # Exposure: +2 when one of the hosts is reachable from the Internet.
158         net = 2 if any(assets[r["host"]]["exposure"] == "internet" for r in rs) else 0
159         # Criticality of the most important host of the group (1 to 3, from the business in
160         crit = max(int(assets[r["host"]]["criticality"]) for r in rs)
161         # The priority score is the sum of the five parts (maximum 10 + 3 + 1 + 2 + 3 = 19
162         total = round(cvss + kev + epss + net + crit, 1)
163         # Find the first class whose minimum the score reaches (the classes are sorted fro
164         cls, days = next((c, d) for m, c, d in CLASSES if total >= m)
165         # Store the action with everything Lab 3 needs.
166         actions.append({"name": name, "hosts": sorted({r["host"] for r in rs}), "cvss": cvs
167                         # Continue the dictionary: the remaining parts of the score and its
```

Step **730** / 1328 · line **156** · the highlighted line has just been executed

VARIABLES CHANGED BY THIS STEP

*no variable changed by this line*

PROGRAM OUTPUT

```
[VERIFY] R17 SW-HQ: QoD 30 < 70 - Telnet: possible vendor
default credentials (login not attempted)
[CONFIRMED] R18 CAM-HQ-3 - Firmware page shows V5.4.0 build
160530; the model family is in the affected list of the
vendor advisory
[CONFIRMED] R20 CAM-HQ-3 - Factory password still in use
(warning sign W-07, Class 1)
[INFO] R25 PC-ADM-01: Operating system detection - Windows 11
Pro 25H2 build 26200
[INFO] R26 NAS-01: Open TCP ports - 22, 139, 445, 5000
[INFO] R27 SALES-LT2: Host did not answer during the scan
(not scanned) - No reply to ARP or ping; laptop off-site
[GROUP] 20 confirmed results -> 16 remediation actions
```

## kalmia_scan_triage.py

- Reads the report header, 27 results, criticality, verification notes
- Filters, removes false positives, groups, scores, sorts
- Output: scan_risk_factors.csv — 16 actions (P1 2)

## Videos (≤ 15 min, verified Nov 6, 2026)

- ▶️ Vulnerability Scans · Professor Messer · 14:52
- ▶️ Analyzing Vulnerabilities · Professor Messer · 10:29
- ▶️ Vulnerability Remediation · Professor Messer · 8:45

# After the lecture — what comes next

| When | What |
|---|---|
| Quiz 2 (Topics 1 – 4) — tonight, after the lecture | Administered separately on the course platform (5 %). It is not part of this module; the flash-cards and formative questions below are practice only and are not evaluated. |
| Hours 2 – 3 — run the three code examples | In teams, run Code examples 1 to 3 on the lab files, compare the outputs with the tables of the real-life examples, and add one Kalmia row to each output with its evidence. |
| Class 7 — Saturday, November 7, 2:00 – 6:00 pm (online) | Midterm review: Topics 1 to 4 in the exam format, an open question period and a progress check on Labs 1 and 2. |
| Midterm exam — Monday, November 9, 6:00 – 10:00 pm, in class, on campus (25 %) | Covers Topics 1 to 4 (Classes 1 to 6). Instructions and permitted materials are announced in Class 7. |
| Lab 2 — Threat catalogue (Integrative Project, Part 2) | Due Saturday, November 14, 2026, at 23:59 Eastern Time, in the Léa drop box (Omnivox). Tonight's vulnerabilities give your threat rows their 'exposure facts'. |
| Class 9 — Thursday, November 12 — Topic 4 (Part 2) | Risk factors of material, software, organizational and human resources, and the internal information sources (penetration test, compliance, incident and monitoring reports). Tonight's three CSV outputs are the starting list of the Class 9 workshop. |
| Lab 3 — Risk register and prioritization (Integrative Project, Part 3) | Starts on Saturday, November 14. Every NA-, SW- and VS- row produced tonight receives a likelihood and an impact in the risk register. |

# Key references (official sites — check each link on VirusTotal first)

- NIST SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments — https://csrc.nist.gov/pubs/sp/800/30/r1/final
- NIST SP 800-115 — Technical Guide to Information Security Testing and Assessment — https://csrc.nist.gov/pubs/sp/800/115/final
- NIST SP 800-40 Rev. 4 — Guide to Enterprise Patch Management Planning — https://csrc.nist.gov/pubs/sp/800/40/r4/final
- Canadian Centre for Cyber Security — Network security zoning (ITSG-38) — https://www.cyber.gc.ca/en/guidance/network-security-zoning-design-considerations-placement-services-within-zones-itsg-38
- CISA — Known Exploited Vulnerabilities (KEV) Catalog — https://www.cisa.gov/known-exploited-vulnerabilities-catalog
- FIRST — Exploit Prediction Scoring System (EPSS) — https://www.first.org/epss/
- FIRST — CVSS v3.1 Specification — https://www.first.org/cvss/v3-1/
- CISA — Binding Operational Directive 23-02: Mitigating the Risk from Internet-Exposed Management Interfaces — https://www.cisa.gov/news-events/directives/binding-operational-directive-23-02
- Microsoft Learn — Windows 11 Home and Pro lifecycle — https://learn.microsoft.com/en-us/lifecycle/products/windows-11-home-and-pro
- PHP — Supported Versions — https://www.php.net/supported-versions.php
- Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0) — https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html

# Thank you — Quiz 2 follows

Quiz 2 (Topics 1 – 4) is administered on the course platform. Class 7 — midterm review — Saturday 2:00 pm. Midterm exam — Monday, November 9, in class. Lab 2 due November 14, 23:59 ET.

*Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together ! · ALL Rights Reserverd*